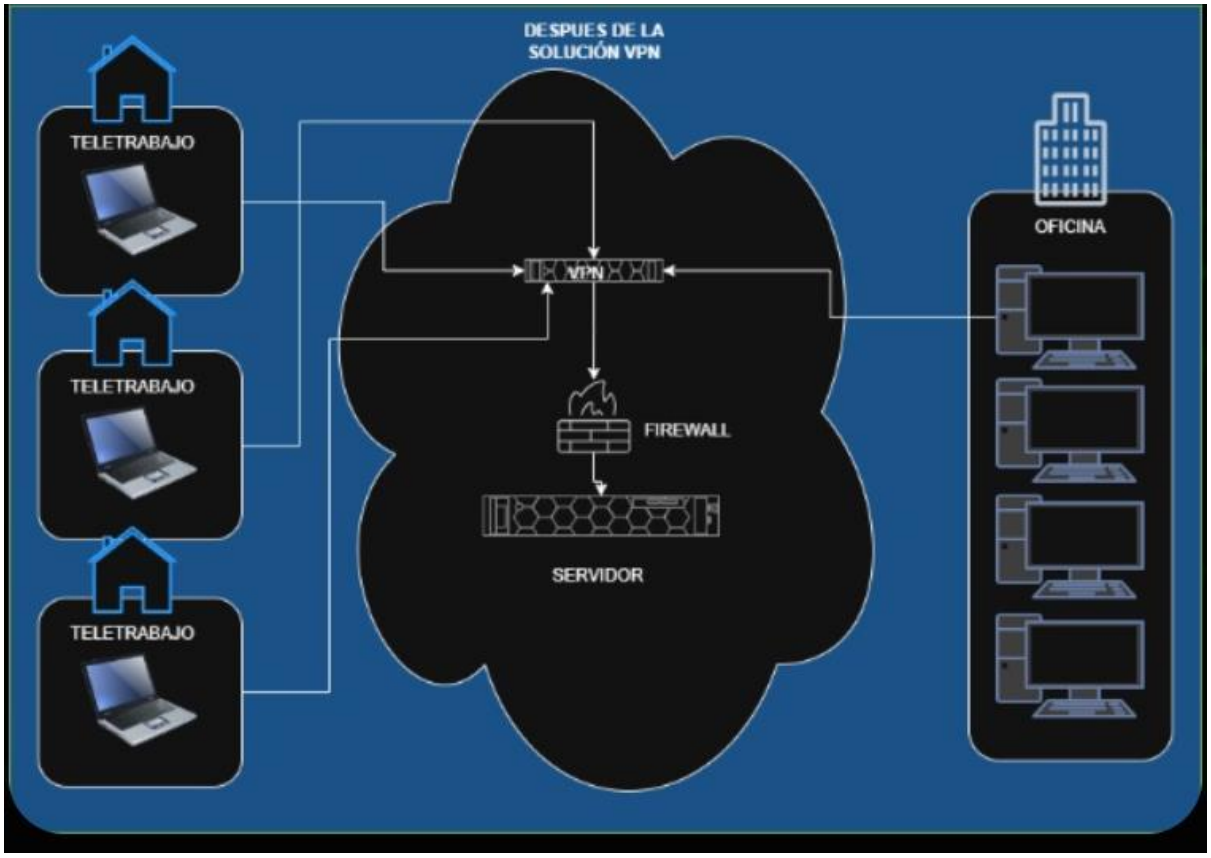
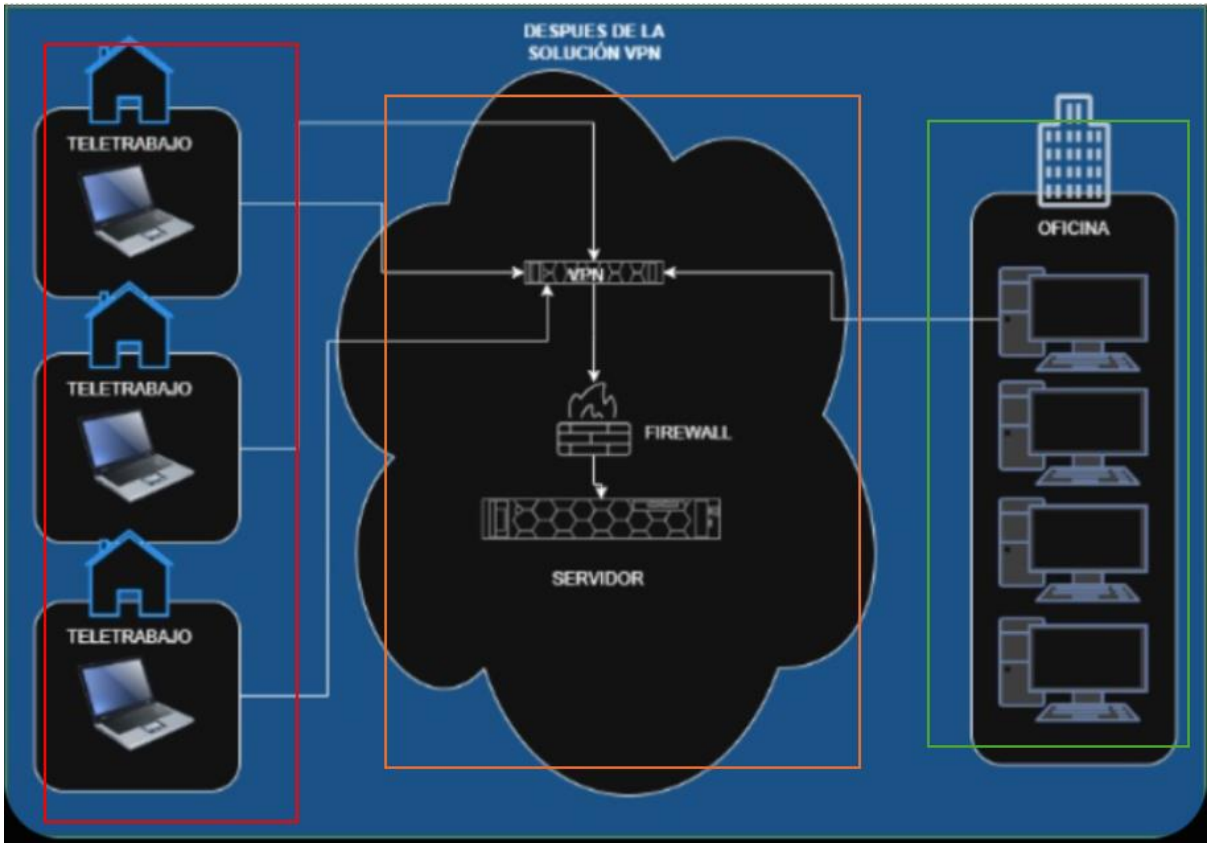
Configuraciones para entorno de teletrabajo



1. Segmentación por Zonas (Aislamiento con Tailscale)

Aunque Tailscale crea una red plana virtual (llamada *Tailnet*), en el Firewall físico (**pfSense/OPNsense**) mantenemos la separación para proteger la oficina física:

- **WAN (Zona Roja):** Internet. Con Tailscale **cerramos todos los puertos de entrada**. Ya no necesitas abrir el 51820 ni ningún otro. El Firewall solo permite salidas, lo que elimina ataques de escaneo de puertos.
- **LAN (Zona Verde):** PCs de la oficina. Se instalan como nodos en la Tailnet.
- **DMZ (Zona Naranja - El Servidor):** El servidor es un nodo crítico. Mediante **ACLs (Listas de Control de Acceso)** en el panel de Tailscale, restringimos que los dispositivos de la LAN vean al servidor, a menos que sea estrictamente necesario.



2. Política "Deny All" (Gestión por ACLs)

En Tailscale, la "llave del hotel" no es un puerto, es la **Identidad del Usuario**.

- **Cómo funciona:** Por defecto, Tailscale permite que todos los nodos de un mismo usuario se vean. Nosotros cambiamos esto a **Modo Restrictivo**.
- **Regla 1 (Acceso al Servidor):** Solo el grupo `group:empleados` puede acceder al `tag:servidor` por los puertos específicos (ej. 443).
- **Regla 2 (Invisibilidad):** Si un dispositivo no está logueado en la Tailnet de la empresa, el servidor es **literalmente inexistente** para él. No hay "agujeros" en el firewall porque Tailscale usa *NAT Traversal* (perfora el firewall desde dentro de forma segura).

3. Inspección y Control (Tailscale + Firewall)

- **Nodos de Salida (Exit Nodes):** Puedes configurar el servidor de la oficina como "Exit Node". Si un empleado se conecta desde un Wi-Fi público, todo su tráfico sale por el Firewall de la oficina, donde aplicamos el **DPI (Inspección Profunda de Paquetes)** de pfSense para filtrar virus.

- **Tailscale SSH:** Permite gestionar el servidor de forma segura sin contraseñas, usando la identidad de Tailscale.

4. Hardware y Costos Reales (Modelo Tailscale)

Concepto	Detalle Técnico	Costo Aproximado (USD)
Hardware Firewall	**Netgate 4100** (Soporta hasta 1Gbps de tráfico VPN).	~$600 - $700 (Pago único)
Licencia Tailscale	Plan **Starter** ($6/mes por usuario).	**$60 / mes** (Para 10 empleados)
Mantenimiento	Revisión de logs, parches de seguridad y bajas.	$100 - $150 / mes

2. (Nueva) Solución VPN: Tailnet (Zero Trust)

Instalamos el agente de **Tailscale**.

- **Experiencia de usuario:** El empleado inicia sesión con su cuenta de Google/Microsoft de la empresa. No hay que enviarle archivos de configuración ni llaves.
- **MagicDNS:** Los empleados acceden al servidor por nombre (ej: `http://servidor-datos/`) en lugar de recordar IPs complejas.
- **Seguridad:** Usa el protocolo de WireGuard (ChaCha20 + Poly1305), pero las llaves se rotan automáticamente cada hora sin que el usuario haga nada.

3. Seguridad de Acceso: MFA e Identidad Nativa

Aquí es donde le ganas a la VPN tradicional:

- **MFA Heredado:** No tienes que configurar un servidor RADIUS complicado. Si la cuenta de correo de la empresa (Google Workspace o Microsoft 365) tiene activado el MFA, **Tailscale lo hereda automáticamente**.
- **Device Check:** Puedes configurar que solo laptops que tengan el disco cifrado o que pertenezcan al dominio de la empresa puedan conectar.
- **Baja Inmediata:** Si desactivas al empleado en el panel de administración de correos, pierde el acceso a la red de la empresa al instante.

4. El Servidor: Hardening con Tailscale

- **Escucha Selectiva (Tailscale IP):** Configuramos el software del servidor (ej. la base de datos) para que solo escuche en la IP asignada por Tailscale (rango `100.x.y.z`).
    - *Resultado:* El servidor es totalmente sordo a cualquier petición que venga de la IP de la oficina local o de internet. Solo "oye" a los que están dentro de la red virtual de Tailscale.
- **ACL de Red (Ejemplo de código):**

En el panel de Tailscale definimos quién entra al servidor `10.0.1.50`:

```
{
  "action": "accept",
  "src":    ["group:contabilidad"],
  "dst":    ["10.0.1.50:443"],
}
```